

Security Assessments

Every organization must perform different types of Security assessments on their networks, computers, and applications at least every so often. The primary purpose of most types of security assessments is to find and confirm vulnerabilities are present, so we can work to patch, mitigate, or remove them. There are different ways and methodologies to test how secure a computer system is. Some types of security assessments are more appropriate for certain networks than others. But they all serve a purpose in improving cybersecurity. All organizations have different compliance requirements and risk tolerance, face different threats, and have different business models that determine the types of systems they run externally and internally. Some organizations have a much more mature security posture than their peers and can focus on advanced red team simulations conducted by third parties, while others are still working to establish baseline security. Regardless, all organizations must stay on top of both legacy and recent vulnerabilities and have a system for detecting and mitigating risks to their systems and data.

Vulnerability Assessment

Vulnerability assessments are appropriate for all organizations and networks. A vulnerability assessment is based on a particular security standard, and compliance with these standards is analyzed (e.g., going through a checklist).

A vulnerability assessment can be based on various security standards. Which standards apply to a particular network will depend on many factors. These factors can include industry-specific and regional data security regulations, the size and form of a company's network, which types of applications they use or develop, and their security maturity level.

Vulnerability assessments may be performed independently or alongside other security assessments depending on an organization's situation.

Penetration Test

Here at Hack The Box, we love penetration tests, otherwise known as pentests.

They're called penetration tests because testers conduct them to determine if and how they can penetrate a network. A pentest is a type of simulated cyber attack, and pentesters conduct actions that a threat actor may perform to see if certain kinds of exploits are possible. The key difference between a pentest and an actual cyber attack is that the former is done with the full legal consent of the entity being pentested. Whether a pentester is an employee or a third-party contractor, they will need to sign a lengthy legal document with the target company that describes what they're allowed to do and what they're not allowed to do.

As with a vulnerability assessment, an effective pentest will result in a detailed report full of information that can be used to improve a network's security. All kinds of pentests can be performed according to an organization's specific needs.

Black box pentesting is done with no knowledge of a network's configuration or applications. Typically a tester will either be given network access (or an ethernet port and have to bypass Network Access Control NAC) and nothing else (requiring them to perform their own discovery for IP addresses) if the pentest is internal, or nothing more than the company name if the pentest is from an external standpoint. This type of pentesting is usually conducted by third parties from the perspective of an external attacker. Often the customer will ask the pentester to show them discovered internal/external IP addresses/network ranges so they can confirm ownership and note down any hosts that should be considered out-of-scope.

Grey box pentesting is done with a little bit of knowledge of the network they're testing, from a perspective equivalent to an employee who doesn't work in the IT department, such as a receptionist or customer service agent. The customer will typically give the tester in-scope network ranges or individual IP addresses in a grey box situation.

White box pentesting is typically conducted by giving the penetration tester full access to all systems, configurations, build documents, etc., and source code if web applications are in-scope. The goal here is to discover as many flaws as possible that would be difficult or impossible to discover blindly in a reasonable amount of time.

Often, pentesters specialize in a particular area. Penetration testers must have knowledge of many different technologies but still will usually have a specialty.

Application pentesters assess web applications, thick-client applications, APIs, and mobile applications. They will often be well-versed in source code review and able to assess a given web application from a black box or white box standpoint (typically a secure code review).

Network or infrastructure pentesters assess all aspects of a computer network, including its networking devices such as routers and firewalls, workstations, servers, and applications. These types of penetration testers typically must have a strong understanding of networking, Windows, Linux, Active Directory, and at least one scripting language. Network vulnerability scanners, such as Nessus, can be used alongside other tools during network pentesting, but network vulnerability scanning is only a part of a proper pentest. It's important to note that there are different types of pentests (evasive, non-evasive, hybrid evasive). A scanner such as Nessus would only be used during a non-evasive pentest whose goal is to find as many flaws in the network as possible. Also, vulnerability scanning would only be a small part of this type of penetration test. Vulnerability scanners are helpful but limited and cannot replace the human touch and other tools and techniques.

Physical pentesters try to leverage physical security weaknesses and breakdowns in processes to gain access to a facility such as a data center or office building.

Can you open a door in an unintended way?

Can you tailgate someone into the data center?

Can you crawl through a vent?

Social engineering pentesters test human beings.

Can employees be fooled by phishing, vishing (phishing over the phone), or other scams?

Can a social engineering pentester walk up to a receptionist and say, "yes, I work here?"

Pentesting is most appropriate for organizations with a medium or high security maturity level. Security maturity measures how well developed a company's cybersecurity program is, and security maturity takes years to build. It involves hiring knowledgeable cybersecurity professionals, having well-designed security policies and enforcement (such as configuration, patch, and vulnerability management), baseline hardening standards for all device types in the network, strong regulatory compliance, well-executed cyber incident response plans, a seasoned CSIRT (computer security incident response team), an established change control process, a CISO (chief information security officer), a CTO (chief technical officer), frequent security testing performed over the years, and strong security culture. Security culture is all about the attitude and habits employees have toward cybersecurity. Part of this can be taught through security awareness training programs and part by building security into the company's culture. Everyone, from secretaries to sysadmins to C-level staff, should be security conscious, understand how to avoid risky practices, and be educated on recognizing suspicious activity that should be reported to security staff.

Organizations with a lower security maturity level may want to focus on vulnerability assessments because a pentest could find too many vulnerabilities to be useful and could overwhelm staff tasked with remediation. Before penetration testing is considered, there should be a track record of vulnerability assessments and actions taken in response to vulnerability assessments.

Vulnerability Assessments vs. Penetration Tests

Vulnerability Assessments and Penetration Tests are two completely different assessments. Vulnerability assessments look for vulnerabilities in networks without simulating cyber attacks. All companies should perform vulnerability assessments every so often. A wide variety of security standards could be used for a vulnerability assessment, such as GDPR compliance or OWASP web application security standards. A vulnerability assessment goes through a checklist.

Do we meet this standard?

Do we have this configuration?

During a vulnerability assessment, the assessor will typically run a vulnerability scan and then perform validation on critical, high, and medium-risk vulnerabilities. This means that they will show evidence that the vulnerability exists and is not a false positive, often using other tools, but will not seek to perform privilege escalation, lateral movement, post-exploitation, etc., if they validate, for example, a remote code execution vulnerability.

Penetration tests, depending on their type, evaluate the security of different assets and the impact of the issues present in the environment. Penetration tests can include manual and automated tactics to assess an organization's security posture. They also often give a better idea of how secure a company's assets are from a testing perspective. A pentest is a simulated cyber attack to see if and how the network can be penetrated. Regardless of a company's size, industry, or network design, pentests should only be performed after some vulnerability assessments have been conducted successfully and with fixes. A business can do vulnerability assessments and pentests in the same year. They can complement each other. But they are very different sorts of security tests used in different situations, and one isn't "better" than the other.

Penetration Testing vs Vulnerability Assessments: Penetration Testing provides in-depth analysis and tailored recommendations but is costly and requires expertise. Vulnerability Assessments are cost-effective and require less skill but may miss vulnerabilities and provide generic recommendations.

Adapted from the original graphic found [here](#).

An organization may benefit more from a vulnerability assessment over a penetration test if they want to receive a view of commonly known issues monthly or quarterly from a third-party vendor. However, an organization would benefit more from a penetration test if they are looking for an approach that utilizes manual and automated techniques to identify issues outside of what a vulnerability scanner would identify during a vulnerability assessment. A penetration test could also illustrate a real-life attack chain that an attacker could utilize to access an organization's environment. Individuals performing penetration tests have specialized expertise in network testing, wireless testing, social engineering, web applications, and other areas.

For organizations that receive penetration testing assessments on an annual or semi-annual basis, it is still crucial for those organizations to regularly evaluate their environment with internal vulnerability scans to identify new vulnerabilities as they are released to the public from vendors.

Other Types of Security Assessments

Vulnerability assessments and penetration tests are not the only types of security assessments that an organization can perform to protect its assets. Other types of assessments may also be necessary, depending on the type of the organization.

Security Audits

Vulnerability assessments are performed because an organization chooses to conduct them, and they can control how and when they're assessed. Security audits are different. Security audits are typically requirements from outside the organization, and they're typically mandated by government agencies or industry associations to assure that an organization is compliant with specific security regulations.

For example, all online and offline retailers, restaurants, and service providers who accept major credit cards (Visa, MasterCard, AMEX, etc.) must comply with the PCI-DSS "Payment Card Industry Data Security Standard". PCI DSS is a regulation enforced by the Payment Card Industry Security Standards Council, an organization run by credit card companies and financial service industry entities. A company that accepts credit and debit card payments may be audited for PCI DSS compliance, and noncompliance could result in fines and not being allowed to accept those payment methods anymore.

Regardless of which regulations an organization may be audited for, it's their responsibility to perform vulnerability assessments to assure that they're compliant before they're subject to a surprise security audit.

Bug Bounties

Bug bounty programs are implemented by all kinds of organizations. They invite members of the general public, with some restrictions (usually no automated scanning), to find

security vulnerabilities in their applications. Bug bounty hunters can be paid anywhere from a few hundred dollars to hundreds of thousands of dollars for their findings, which is a small price to pay for a company to avoid a critical remote code execution vulnerability from falling into the wrong hands.

Larger companies with large customer bases and high security maturity are appropriate for bug bounty programs. They need to have a team dedicated to triaging and analyzing bug reports and be in a situation where they can endure outsiders looking for vulnerabilities in their products.

Companies like Microsoft and Apple are ideal for having bug bounty programs because of their millions of customers and robust security maturity.

Red Team Assessment

Companies with larger budgets and more resources can hire their own dedicated red teams or use the services of third-party consulting firms to perform red team assessments. A red team consists of offensive security professionals who have considerable experience with penetration testing. A red team plays a vital role in an organization's security posture.

A red team is a type of evasive black box pentesting, simulating all kinds of cyber attacks from the perspective of an external threat actor. These assessments typically have an end goal (i.e., reaching a critical server or database, etc.). The assessors only report the vulnerabilities that led to the completion of the goal, not as many vulnerabilities as possible as with a penetration test.

If a company has its own internal red team, its job is to perform more targeted penetration tests with an insider's knowledge of its network. A red team should constantly be engaged in red teaming campaigns. Campaigns could be based on new cyber exploits discovered through the actions of advanced persistent threat groups (APTs), for example. Other campaigns could target specific types of vulnerabilities to explore them in great detail once an organization has been made aware of them.

Ideally, if a company can afford it and has been building up its security maturity, it should conduct regular vulnerability assessments on its own, contract third parties to perform penetration tests or red team assessments, and, if appropriate, build an internal red team to perform grey and white box pentesting with more specific parameters and scopes.

Purple Team Assessment

A blue team consists of defensive security specialists. These are often people who work in a SOC (security operations center) or a CSIRT (computer security incident response team). Often, they have experience with digital forensics too. So if blue teams are defensive and red teams are offensive, red mixed with blue is purple.

What's a purple team?

Purple teams are formed when offensive and defensive security specialists work together with a common goal, to improve the security of their network. Red teams find security problems, and blue teams learn about those problems from their red teams and work to fix them. A purple team assessment is like a red team assessment, but the blue team is also involved at every step. The blue team may even play a role in designing campaigns. "We need to improve our PCI DSS compliance. So let's watch the red team pentest our point-of-sale systems and provide active input and feedback during their work."